# UNDERWRITE Security Self-Assessment & Threat Model

> **A Formal Threat Model, Invariant Verification Matrix, and Known Risk Catalog**
>
> FinTechathon 2026 — Topic F Security Reference

# 1. Threat Model & Adversarial Capabilities

UNDERWRITE models accounts-payable automation as a multi-adversary environment with distinct attacker profiles:

| Adversary | Attacker Capability | System Barrier & Mitigation | Worst-Case Outcome By Design |
|---|---|---|---|
| **External Invoice Attacker** | Crafts malicious invoices, prompts, and spoofed bank details sent via email | • Deterministic Policy Firewall checks supplier registry and cooldowns.<br>• Non-whitelisted addresses are strictly rejected ( `POL_RECIPIENT_NOT_ALLOWED` ). | Zero funds transferred. Proposal diverted to human T2 review or rejected. |

## 2. Invariant Verification Matrix (INV-1 through INV-14)

Every security invariant defined in `plan.md` §9.8 is enforced by smart contracts and verified by automated Foundry test suites (including stateful property-based invariant testing and fuzzing):

| Invariant | Formal Statement | |
|---|---|---|
| **INV-1** | Agent keys can move tokens ONLY through `pay()` and `requestPayment()` $\rightarrow$ `executePending()`. No direct transfer, approval, or arbitrary execution tools exist. | • `contract` • `contrac` |
| **INV-2** | For every qualification and 24h window: $\sum T_1$ payments $\leq$ effective $t1MaxPerWindow$. | • `contrac` • `contrac` • `contrac` |
| **INV-3** | Every $T_1$ payment $\leq$ effective $t1MaxPerTx$; every $T_2$ request $\leq t2MaxPerTx$ | • `contrac` • `contrac` |

## 3. Known Risks & Disclosures (KR-1 through KR-6)

In compliance with hackathon security standards and honest disclosure rules:

### KR-1: Owner Key Custody in Demo

- **Risk:** In the local demo runner ( `scripts/demo-local.sh` ), the owner private key resides unencrypted in memory and environment files.
- **Mitigation:** Production deployment requires smart contract account abstraction (ERC-4337 / Safe multi-sig) or hardware security modules (HSM) for owner transactions.

### KR-2: Agent Private Keys on Local Disk

- **Risk:** Agent keys generated by `uw keys new` are saved in `.keys/` on the local file system.
- **Mitigation:** Protected by `.gitignore` to prevent secret leakage. For enterprise use,